

Company: SecureCloud Solutions, Inc.

Title: Incident Response Policy & Procedures

Version: 1.2

Effective Date: August 1, 2025

Owner: Chief Information Security Officer (CISO)

Reviewed: Annually

1. Purpose

This policy establishes SecureCloud Solutions' requirements for detecting, reporting, responding to, and recovering from security incidents. It ensures incidents are handled in a timely, consistent, and documented manner, minimizing damage and supporting compliance with legal, regulatory, and contractual obligations.

2. Scope

This policy applies to all employees, contractors, vendors, systems, networks, and data owned or managed by SecureCloud Solutions, including cloud infrastructure, applications, endpoints, and third-party services.

3. Definitions

- Security Event: Any observable occurrence in a system or network indicating potential security violation, anomaly, or threat.
- Security Incident: A security event (or combination thereof) that compromises confidentiality, integrity, or availability of information systems or data.
- Incident Response Team (IRT): A group comprised of security engineers, legal counsel, communications staff, and senior management responsible for incident handling.

4. Roles & Responsibilities

- CISO: Owns the policy, ensures resources, approves major decisions.
- Incident Response Team Lead: Oversees incident lifecycle: detection, analysis, containment, eradication, recovery, and post-incident review.
- Security Engineers: Monitor, investigate, collect logs and evidence, perform remediation.
- Legal & Compliance: Evaluate regulatory impact, handle notifications (to regulators or affected parties).
- Communications Officer: Internal and external reporting, liaising with stakeholders and media.

5. Policy Requirements

5.1 Detection & Reporting

- All personnel must report any suspected or confirmed security events immediately to the IRT via the internal ticketing system.

- Security monitoring tools (SIEM, IDS/IPS, cloud guard services) must be enabled to generate alerts for anomalous behavior.

5.2 Response & Handling

- Incidents will be classified by severity based on impact to data sensitivity, user safety, operations, or reputation.

- The IRT will initiate response according to the incident type and severity:

1. Containment: Limit spread or damage.
2. Eradication: Identify and eliminate root cause (e.g., malware, misconfiguration).
3. Recovery: Restore systems to normal operation, validate they are clean.

5.3 Post-Incident Activities

- After recovery, the IRT will conduct a post-incident review to identify root causes, lessons learned, and actions to prevent recurrence.

- Incident report (including timeline, affected systems, causes, remediation, impact) must be documented and stored for a minimum of three years.

5.4 Notification & Communication

- Legal & Compliance lead must determine whether the incident triggers obligations under applicable laws, contracts, or regulations (e.g., data breach laws, FedRAMP, contracts).

- External communication to customers, regulators, or media must follow pre-approved templates and must be approved by senior management.

5.5 Training & Testing

- The IRT must conduct tabletop exercises at least annually.
- All relevant staff (employees, contractors) must receive incident response awareness training within 90 days of hire and every 12 months afterward.

6. Review & Updates

- This policy is reviewed at least annually and whenever there is a significant incident, change in regulatory requirements, or major change in technology or business model.
- Changes must be approved by the CISO and documented via version control.

7. Related Policies & References

- Change Management Policy
- Data Classification Policy
- Business Continuity / Disaster Recovery Plan
- Acceptable Use Policy

- FedRAMP System Security Plan (SSP) References: IR■4, IR■2, PM■9

Approval

Approved By: Jane Doe, CISO

Date: August 1, 2025